Podstawy Web - Pentest

Spis treści

Przygotowanie środowiska 3

Uruchamianie maszyn 4

Połączenie OpenVPN 5

Niezaliczone zadanie 6

Zadania 7

Zadanie 3.1p: Ciasteczka 8

Zadanie 3.2p: Przekierowanie 10

Zadanie 3.3p: Enumeracja użytkowników 11

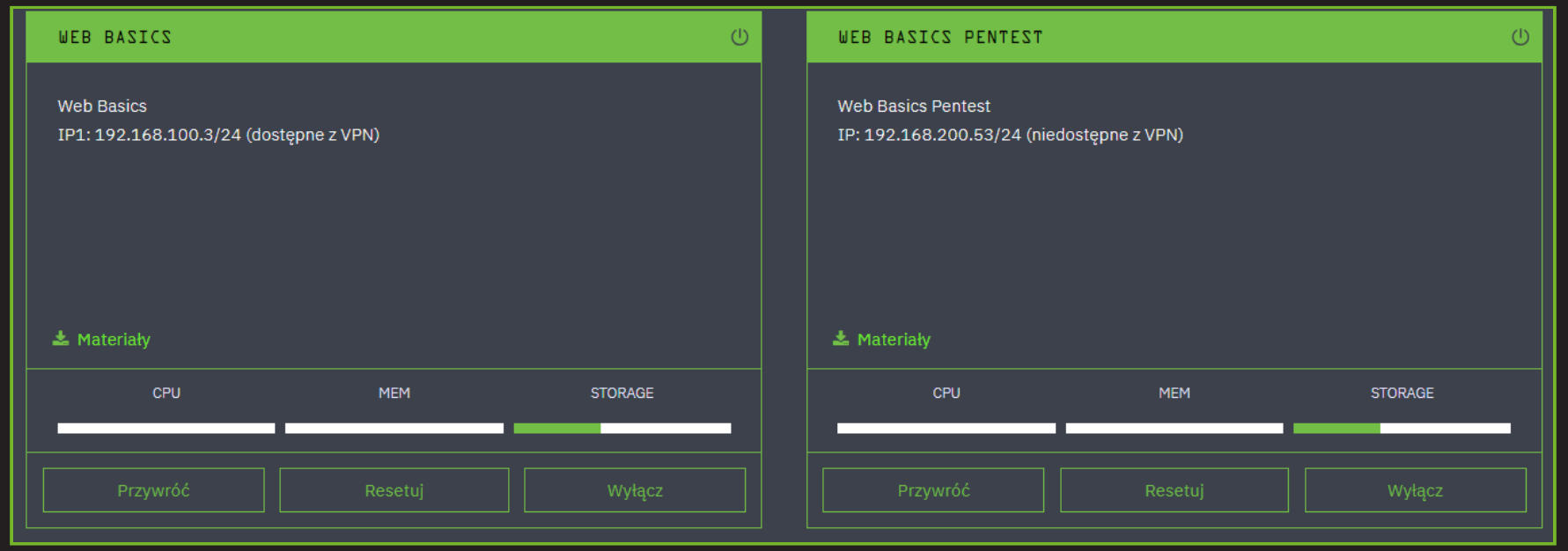
Zadanie 3.4p: Dekodowanie danych 13

Zadanie 3.5p: Deobfuskacja Javascript 14

Przygotowanie środowiska

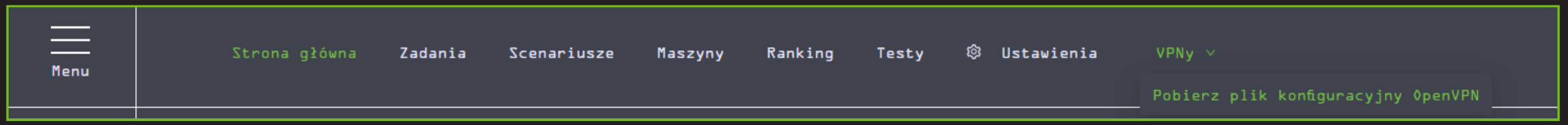
Uruchamianie maszyn

Przed rozpoczęciem upewnij się, że maszyny Web Basics oraz Web Basics PENTEST są włączone. Jeżeli coś się zepsuje, w każdej chwili możesz je przywrócić do stanu początkowego.



Podczas tych zajęć wszystkie polecenia wykonujemy bezpośrednio na maszynie Kali!

Połączenie OpenVPN

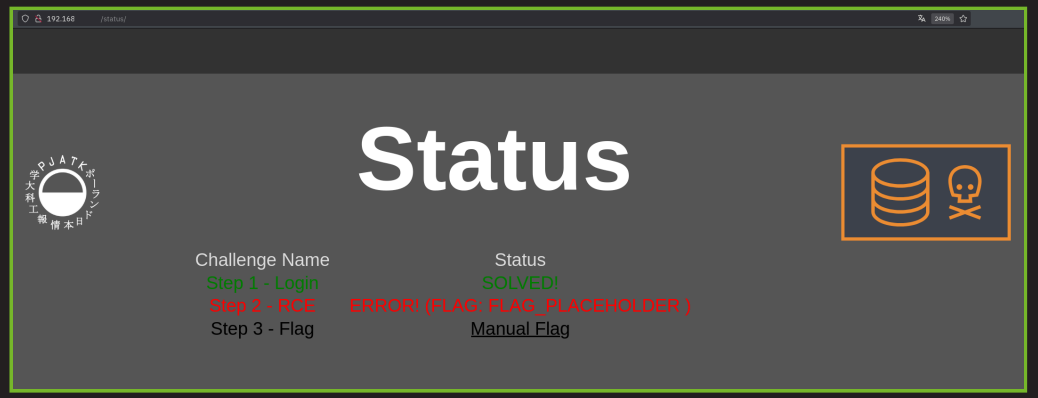


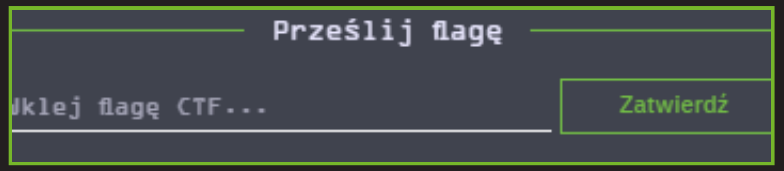
Połączenie OpenVPN jest niezbędne do rozwiązania zadań.
Aby połączyć się z siecią VPN, należy pobrać plik konfiguracyjny OpenVPN z rozwijanego menu „**VPNy**” na stronie głównej.
Następnie należy wykonać komendę:

```
sudo openvpn /sciezka/do/pliku.ovpn
```

Niezaliczone zadanie

Niektóre rozwiązane zadania powinny zaliczać się w systemie automatycznie. Jeśli jednak pojawi się problem i któreś z zadań rozwiążesz prawidłowo, a nadal będzie ono widnieć jako nierozwiązane, możesz odwiedzić podstronę `/status` na maszynie zadaniowej. Tam widnieć będzie flaga, którą możesz wkleić w swoim panelu i zaliczyć zadanie „ręcznie”.



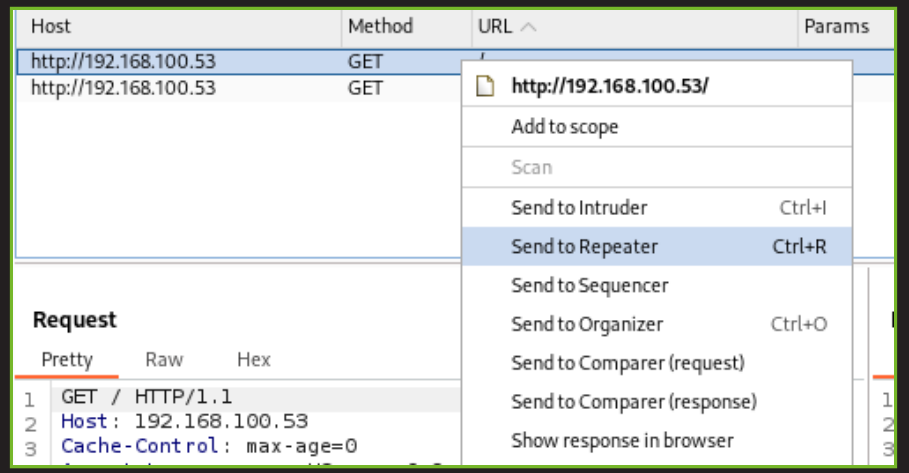


POLSKO-JAPOŃSKA AKADEMIA TECHNIK KOMPUTEROWYCH

Zadania

Zadanie 3.1p: Ciasteczka

Celem zadania jest modyfikacja ciasteczka „admin” z wartości „false” na „true” na stronie http://192.168.100.53/ . Zadanie zostanie automatycznie zaliczone po zmodyfikowaniu ciastka i wysłaniu prawidłowego zapytania, np. za pomocą poznanego *Repeatera* lub *Intercept*.



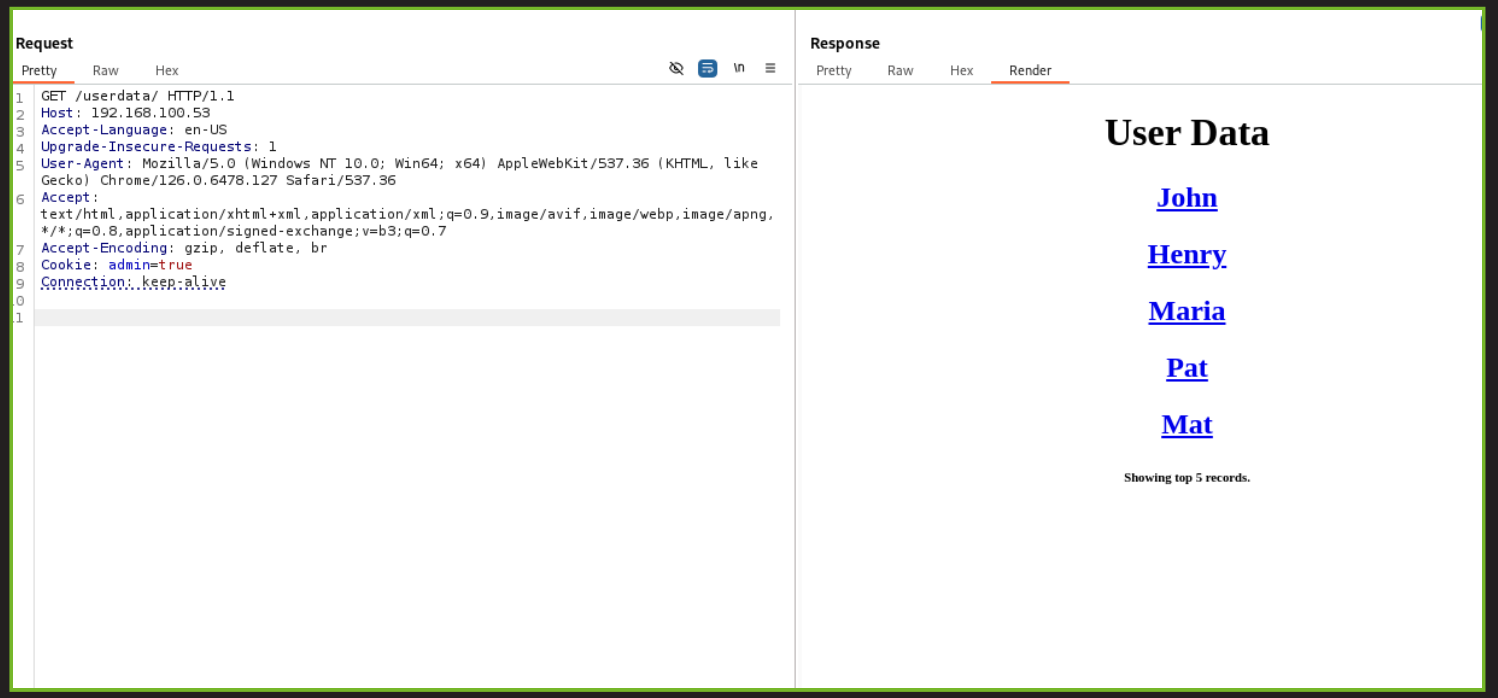
Zadanie 3.1p: Ciasteczka





Zadanie 3.2p: Przekierowanie

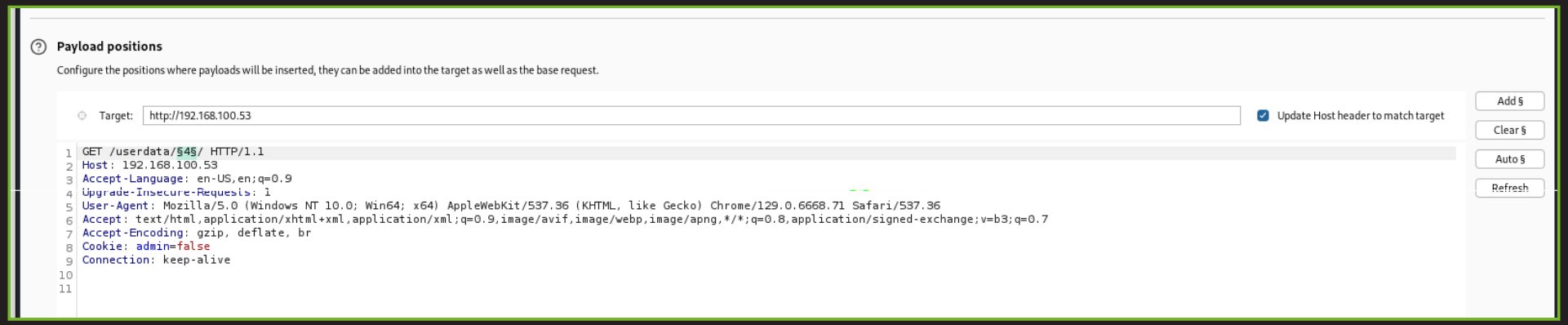
Celem zadania jest ominięcie przekierowania na stronie http://192.168.100.53/login/
Można to zrobić wyświetlając odpowiedź HTTP w historii HTTP Burp. Zadanie zostanie automatycznie zaliczone po wejściu do panelu admina.



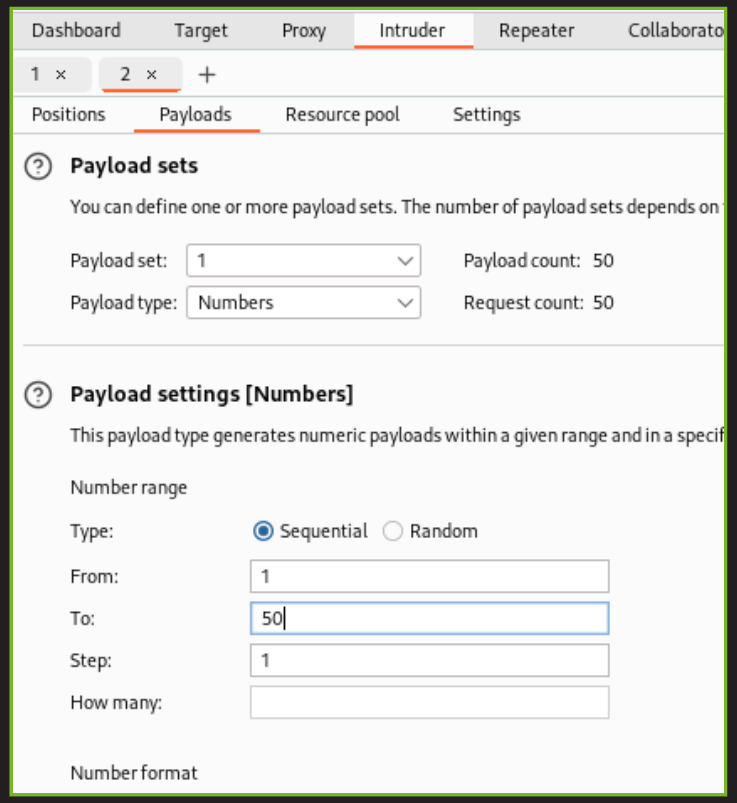


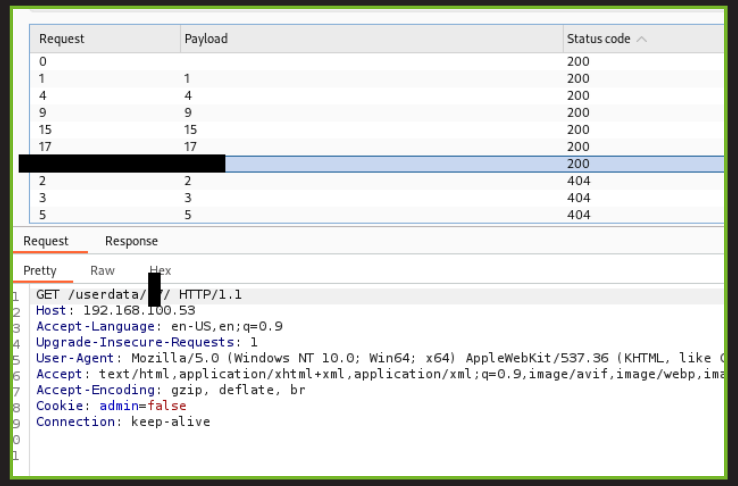
Zadanie 3.3p: Enumeracja użytkowników

Celem zadania jest enumeracja użytkowników po ID w panelu admina. Można to zrobić wykorzystując narzędzie *Intruder* i typ payloadu *Numbers (1-50)*. Aby ustalić, gdzie Intruder będzie zmieniał wartości, zaznacz odpowiedni fragment adresu celu i kliknij opcję Add §.



Zadanie 3.3p: Enumeracja użytkowników

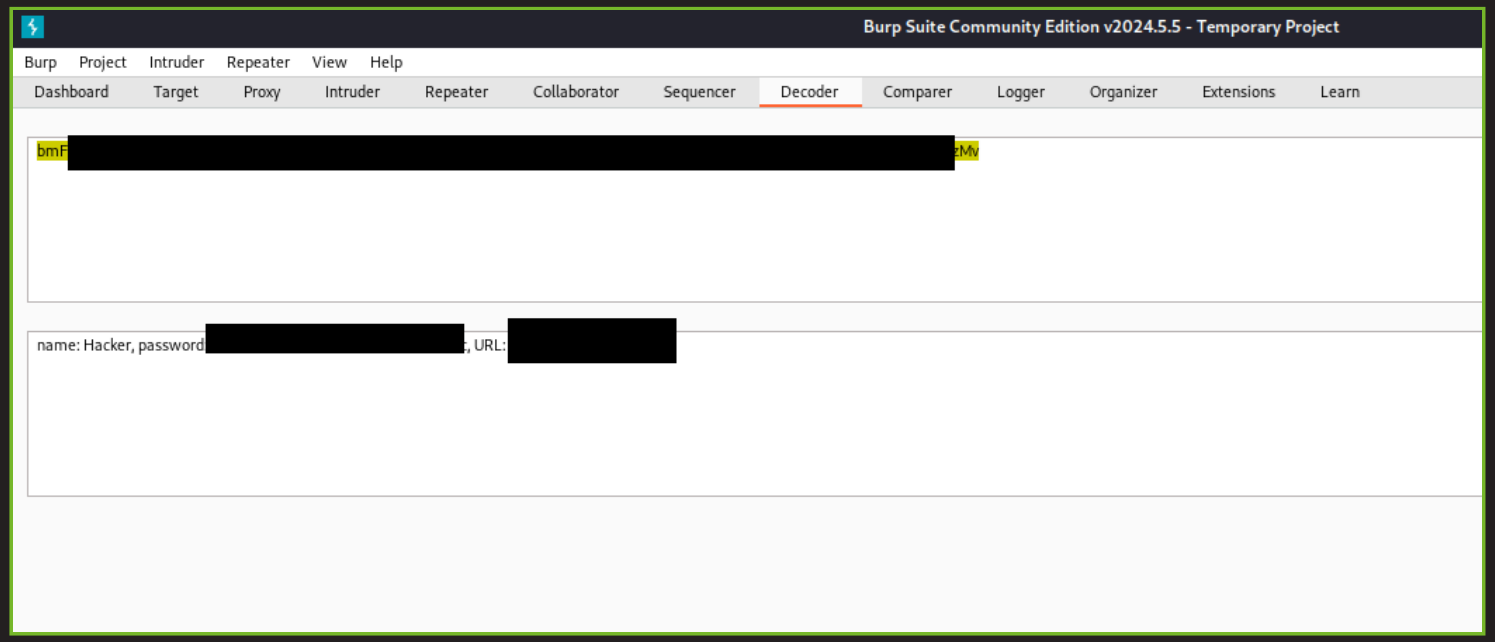






Zadanie 3.4p: Dekodowanie danych

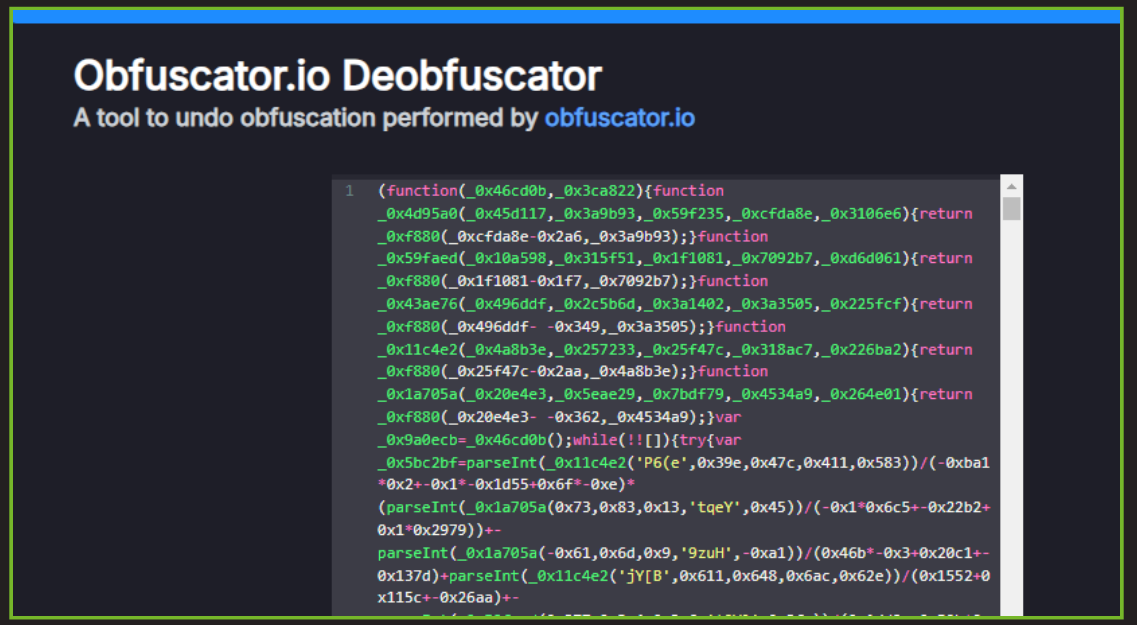
Zadanie zostanie automatycznie zaliczone po wejściu na unikalny URL użytkownika Hacker. Użyj do tego zakładki Decoder.





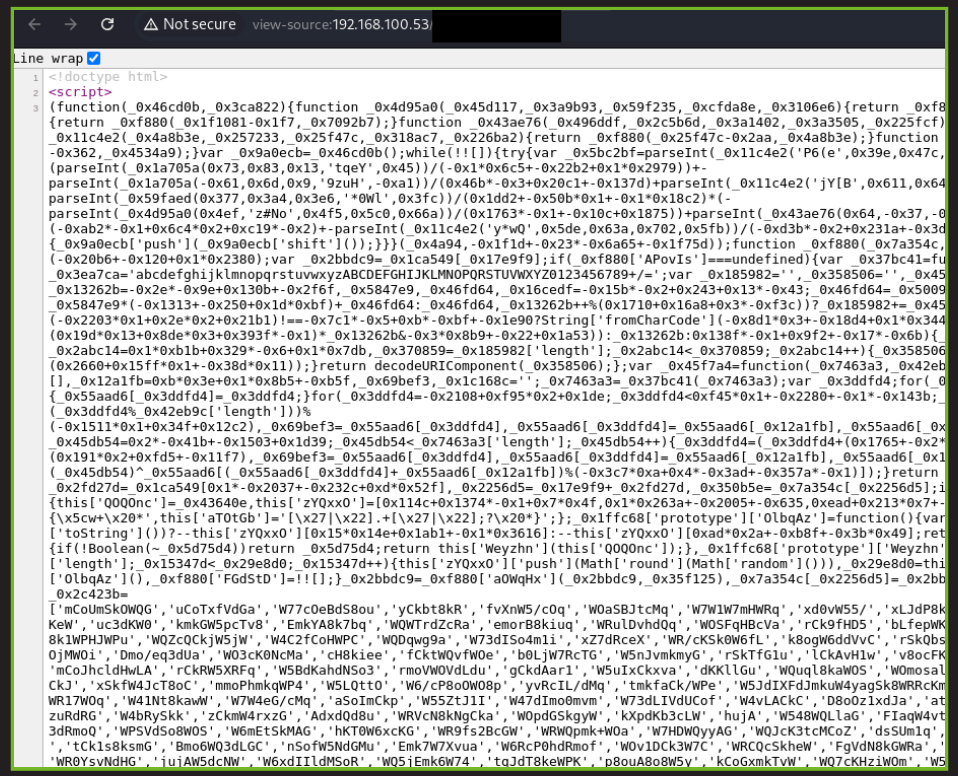
Zadanie 3.5p: Deobfuskacja Javascript

Celem zadania jest deobfuskacja kodu Javascript na stronie użytkownika Hacker. Istnieje wiele narzędzi do tego celu, my dziś użyjemy:
https://obf-io.deobfuscate.io/



Zadanie 3.5p: Deobfuskacja Javascript

Zacznijmy od zerknięcia w źródło strony. Znajduje się tam kod Javascript, jednak został on celowo „zaciemniony”.



Zadanie 3.5p: Deobfuskacja Javascript

Skopiujmy cały kod i wklejmy do wybranego przez nas narzędzia. Jeśli natrafisz na błąd - usuń znaczniki HTML, zostawiając tylko sam Javascript.

Czytając zdeobfuscowany kod źródłowy, należy zwrócić uwagę na podejrzany ciąg znaków:

```
if(secret)
  location.href="secret1337.php"
```

Zadanie zostanie rozwiązane po otworzeniu powyższego pliku.

Zadanie 3.5p: Deobfuskacja Javascript

